

# Engenharia de Segurança da Informação (PARTE 1)

Engenharia de Qualidade e Confiabilidade

Prof. Me. Sergio Souza Novak — UniRV

16 de abril de 2026



## 1 Fundamentos e Contexto

- Evolução Histórica
- Cenário de Ameaças
- Malwares e Software Malicioso
- Resiliência e Riscos

## 2 Dimensões da Segurança

- A Tríade CIA
- Níveis e Camadas
- Gestão e Fator Humano

## 3 Dependabilidade e Terminologia

- Conceitos de Dependabilidade
- Dicionário de Segurança
- Mentcare: Estudo de Caso

## 4 Vulnerabilidades e Fatores Humanos

- Origem das Falhas
- Configuração e Projeto

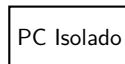
## 5 Ameaças e Estudos de Caso

- Tipologia de Ameaças
- Confidencialidade e Disponibilidade
- Integridade e Fabricação

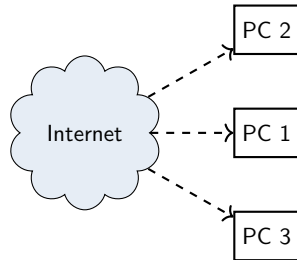
# Fundamentos e Contexto

# Contexto Histórico: A Década de 1990

- Adoção generalizada da Internet.
- Surgimento de um novo desafio para engenheiros de software.
- Transição do processamento isolado para a conectividade global.



Anos 80

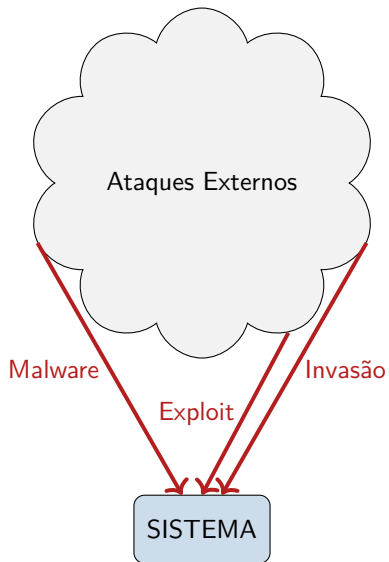


Anos 90

## Projetar e Implementar Sistemas Seguros

Com a conectividade, a segurança deixou de ser um recurso opcional para se tornar um requisito fundamental da engenharia de software.

- Mudança de foco: Validar não apenas o que o sistema **deve fazer**, mas também o que ele **não deve permitir**.
- Impacto direto na confiabilidade do sistema.



# Classificação de Ataques

Os ataques podem ser divididos em duas grandes categorias:

| <b>Tipo</b>    | <b>Descrição</b>                                                                                                                    |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------|
| <b>Passivo</b> | O atacante observa ou monitora o tráfego sem alterar os dados. O objetivo é a obtenção de informação (quebra de confidencialidade). |
| <b>Ativo</b>   | O atacante tenta alterar os recursos do sistema ou afetar sua operação. Envolve modificação, fabricação ou interrupção.             |

## Diferença Crucial

Ataques passivos são difíceis de detectar (pois não há alteração), enquanto ataques ativos são difíceis de prevenir (devido à complexidade das vulnerabilidades).

# Malwares: Definição e Tipos

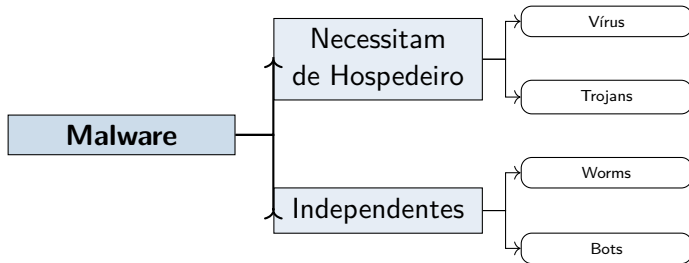
Programas maliciosos, ou **malware**, são softwares criados para danificar, roubar dados ou acessar sistemas sem autorização.

## Tipos mais comuns:

- **Vírus:** Anexa-se a programas legítimos e exige execução humana.
- **Worms:** Independentes, espalham-se sozinhos pela rede.
- **Trojans:** "Presentes de Grego" que escondem código malicioso.
- **Ransomware:** Sequestra dados via criptografia e exige resgate.
- **Spyware:** Coleta informações do usuário silenciosamente.



# Taxonomia de Malware



# Exemplo de Código: Lógica de Propagação (Worm)

## Simulação Conceitual (Pseudocódigo)

INICIO

FUNCAO propagar\_worm()

arquivo\_atual ← ESTE\_ARQUIVO

PARA CADA pasta EM REDE\_COMPARTILHADA

destino ← pasta + "/update\_system"

SE destino NAO EXISTE ENTAO

COPIAR arquivo\_atual PARA destino

EXIBIR "Propagado para: " + destino

FIM SE

FIM PARA

FIM FUNCAO

# Execucao automatica (sem interacao do usuario)

FIM

# Exemplo de Código: Carga Útil (Ransomware)

## Criptografia de Arquivos (Pseudocódigo)

INICIO

FUNCAO criptografar\_dados(chave)

  PARA CADA arquivo EM DIRETORIO\_USUARIO

    SE arquivo FOR DO TIPO (docx, pdf, jpg) ENTAO

      dados ← LER arquivo

      dados\_criptografados ← CRIPTOGRAFAR(dados, chave)

      ESCREVER dados\_criptografados NO arquivo

    FIM SE

  FIM PARA

  EXIBIR "Seus arquivos foram criptografados"

  EXIBIR "Pague para recuperar o acesso"

FIM FUNCAO

FIM

## Atacantes Externos:

- Maliciosos.
- Altamente qualificados tecnicamente.
- Motivados (financeiro, político, etc).

## Problemas no Desenvolvimento:

- Erros acidentais (bugs).
- Má configuração.
- Falta de diretrizes de segurança no ciclo de vida.



## Impacto do Comprometimento

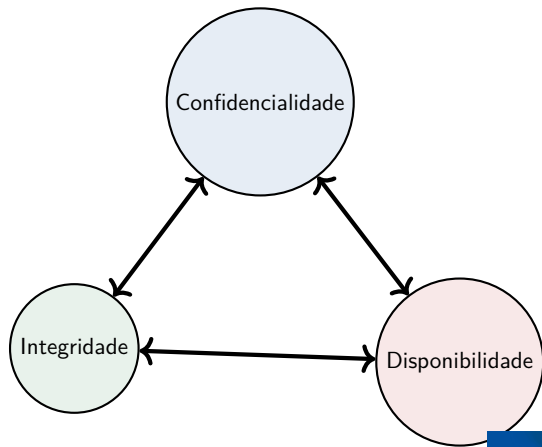
Um atacante bem-sucedido pode causar danos irreversíveis:

- ❶ **Mau uso do hardware:** Utilização de recursos para fins ilícitos (ex: botnets).
- ❷ **Roubo de dados:** Vazamento de informações contridenciais e sensíveis.
- ❸ **Perturbação de serviços:** Interrupção da disponibilidade para usuários legítimos.

# Dimensões da Segurança

# Dimensões da Segurança (Tríade CIA)

- **Confidencialidade:** Proteção contra acesso não autorizado (ex: roubo de dados).
- **Integridade:** Garantia de que a informação não foi corrompida (ex: worms).
- **Disponibilidade:** Garantia de acesso quando necessário (ex: ataques DoS).



As três dimensões estão intimamente ligadas:

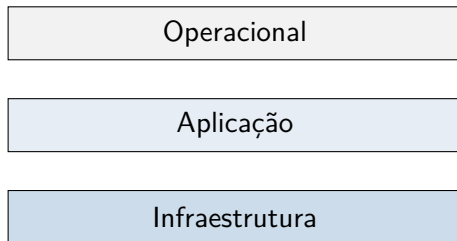
- **Indisponibilidade** → **Falta de Integridade**: Se o sistema cai, informações temporais não são atualizadas.
- **Comprometimento da Integridade** → **Indisponibilidade**: O sistema pode precisar ser desligado para correções após um ataque.

## Efeito Cascata

A falha em um pilar frequentemente compromete a eficácia dos outros dois.

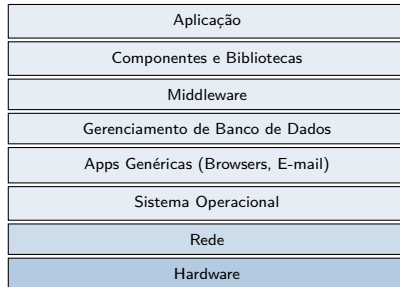
# Níveis de Segurança Organizacional

- ① **Segurança de Infraestrutura:** Sistemas e redes compartilhados.
- ② **Segurança de Aplicação:** Focada em cada sistema de aplicação.
- ③ **Segurança Operacional:** Relacionada ao uso seguro dos sistemas.



# Camadas do Sistema (Pilha de Infraestrutura)

A segurança pode ser comprometida em múltiplos níveis, desde o hardware até a aplicação.

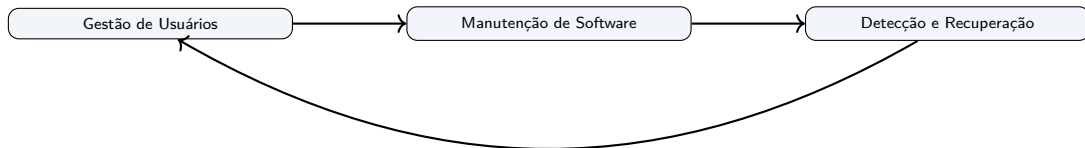


- Atacantes focam na infraestrutura (browsers, SO, DBMS) porque estão disponíveis universalmente.
- Vulnerabilidades descobertas em um componente comum têm ampla aplicabilidade.
- Redes também são alvos, mas exigem equipamentos mais especializados para interceptação.

## Aplicabilidade Ampla

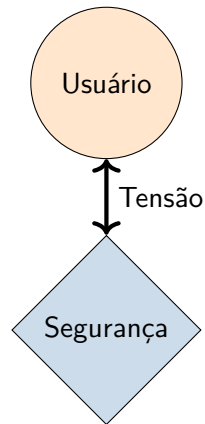
Um exploit em um navegador popular pode atingir milhões de usuários simultaneamente.

- 1 **Usuários e Permissões:** Autenticação rigorosa e princípio do menor privilégio.
- 2 **Instalação e Manutenção:** Configuração correta e atualização constante (patches).
- 3 **Monitoramento e Recuperação:** Detecção de intrusão e estratégias de backup.



# Segurança Operacional (Fator Humano)

- Focada no comportamento das pessoas que usam o sistema.
- **Desafio:** Equilibrar segurança rigorosa com a eficácia no trabalho.
- **Risco:** Usuários frequentemente ignoram regras de segurança para ganhar tempo.



## Definição Abrangente

Proteção de cidadãos, empresas e infraestruturas críticas contra ameaças surgidas do uso da Internet e computadores.

- Escopo: Desde o hardware e redes até dispositivos móveis e aplicações.
- Intimamente ligada à **Engenharia de Resiliência**.

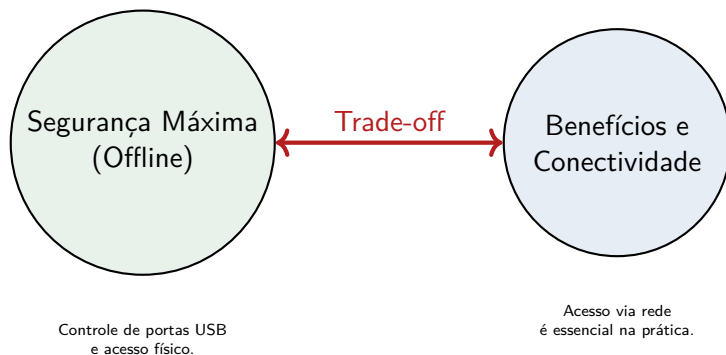
# Dependabilidade e Terminologia

## Definição

Atributo que reflete a capacidade do sistema de se proteger contra ataques maliciosos internos ou externos.

- **Ataques Externos:** Possíveis devido à conectividade global.
- **Ataques Internos:** Realizados por usuários autorizados que abusam de privilégios.
- **Exemplos:** Vírus, Cavalos de Tróia, modificação não autorizada de dados.

# O Dilema da Conectividade



## Interpretação

Quanto maior o isolamento de um sistema (offline), maior tende a ser sua segurança contra ataques externos. Por outro lado, a conectividade em rede aumenta a produtividade e a integração, mas também amplia a superfície de ataque. O desafio é encontrar um equilíbrio adequado entre proteção e usabilidade.

# Importância da Segurança: Exemplos

Nem todos os sistemas sofrem o mesmo impacto com falhas de segurança:

## Inconveniente

### *Reserva de Passagens*

Indisponibilidade causa atrasos e desconforto.

## Catastrófico

### *Exclusão de Registros*

Se um atacante apaga todas as reservas, a operação para.

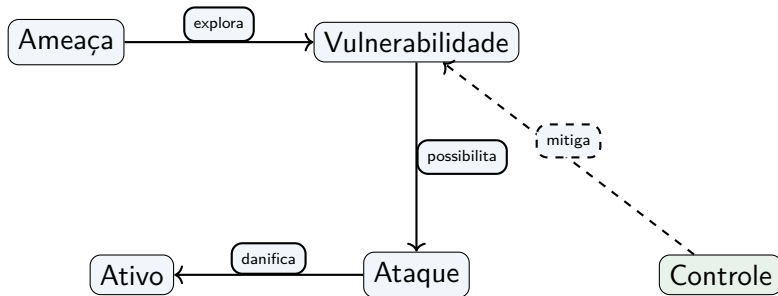
## Sistemas Críticos

Sistemas militares, e-commerce e processamento de dados confidenciais exigem níveis máximos de proteção.



| <b>Termo</b>           | <b>Definição</b>                                                  |
|------------------------|-------------------------------------------------------------------|
| <b>Ativo</b>           | Algo de valor que precisa ser protegido (dados ou software).      |
| <b>Ataque</b>          | Aproveitamento de uma vulnerabilidade para causar dano.           |
| <b>Controle</b>        | Medida de proteção que reduz a vulnerabilidade (ex: encriptação). |
| <b>Exposição</b>       | Possível perda ou dano infligido ao sistema (dados ou tempo).     |
| <b>Ameaça</b>          | Circunstância com potencial para causar perda ou dano.            |
| <b>Vulnerabilidade</b> | Ponto fraco que pode ser aproveitado por um ataque.               |

# Relacionamento entre Conceitos



## História de Segurança: Acesso não Autorizado

Um criminoso tenta acessar dados de um atleta famoso em tratamento na clínica.

- **Cenário:** Funcionários usam usuário e senha (mínimo 8 caracteres).
- **Engenharia Social:** O atacante finge ser um parente para obter nomes de funcionários.
- **Ataque:** Examina crachás para nomes e tenta adivinhar senhas (ex: nomes de filhos).

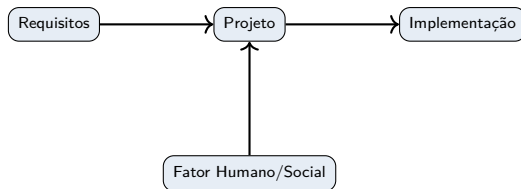
- **Ativo:** Registros de saúde mental do atleta (confidencialidade).
- **Vulnerabilidade:** Senhas fracas e previsíveis escolhidas pelos usuários.
- **Ameaça:** Chantagem baseada no vazamento de informações.
- **Ataque:** Adivinhação sistemática de senhas e engenharia social.
- **Exposição:** Danos à reputação do paciente e da clínica.

# Vulnerabilidades e Fatores Humanos

# Origem das Vulnerabilidades

Vulnerabilidades não surgem apenas de erros de codificação, mas de múltiplas fontes:

- **Requisitos:** Falhas na definição do que deve ser protegido.
- **Projeto:** Arquiteturas que permitem exposições desnecessárias.
- **Implementação:** Bugs de software (ex: buffer overflow).
- **Fatores Externos:** Falhas humanas, sociais ou organizacionais.



As pessoas são frequentemente o "elo mais fraco" na segurança:

- Escolha de senhas fáceis de adivinhar.
- Anotação de senhas em locais visíveis.
- Negligência no uso de softwares de proteção.

## Erro Humano?

Muitas vezes, o que parece ser um erro do usuário é, na verdade, um reflexo de uma decisão de projeto ruim.

# [CS1] Estudo de Caso: O Problema do "Post-it"

**Cenário:** Uma empresa exige que os usuários troquem de senha a cada 15 dias e usem caracteres especiais.

**Resultado:** Os usuários não conseguem memorizar

tantas variações e anexam a senha em um "Post-it" colado no monitor.



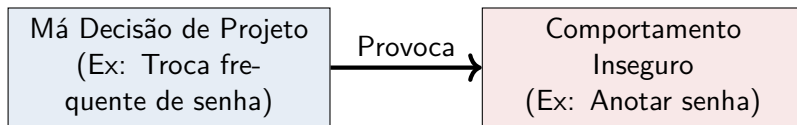
Administradores de sistema também cometem erros críticos:

- Falhas na configuração do controle de acesso.
- Arquivos de configuração "abertos" demais.
- Não instalação de patches de segurança ou atualizações.

## Complexidade

Mecanismos de configuração complexos aumentam drasticamente a probabilidade de erros administrativos.

# Decisões de Projeto vs. Erro Humano



- Se o sistema exige algo impossível do ser humano, a segurança será burlada por conveniência ou necessidade.

- A segurança deve ser considerada em todos os estágios do ciclo de vida.
- **Requisitos Iniciais:** Identificar o que proteger.
- **Operação:** Manter sistemas atualizados e monitorados.

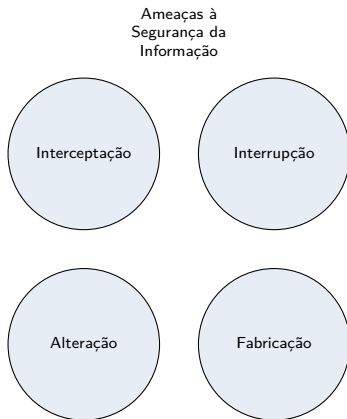
## Segurança não é um "Adicional"

Não se pode "acrescentar" segurança ao final do desenvolvimento; ela deve estar no DNA do projeto.

# Ameaças e Estudos de Caso

# Tipos de Ameaça à Segurança

Podemos classificar as ameaças em quatro categorias fundamentais:



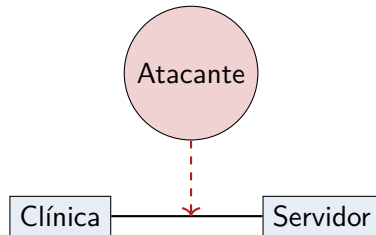
## Definição

Permite que um atacante ganhe acesso não autorizado a um ativo do sistema.

- Compromete a **Confidencialidade**.
- Pode ocorrer via escuta de rede (sniffing), acesso físico a arquivos ou engenharia social.
- **Mentcare**: Um atacante lendo registros de pacientes sem permissão.

**Cenário:** Um hacker intercepta os pacotes de rede transmitidos entre a clínica e o servidor central.

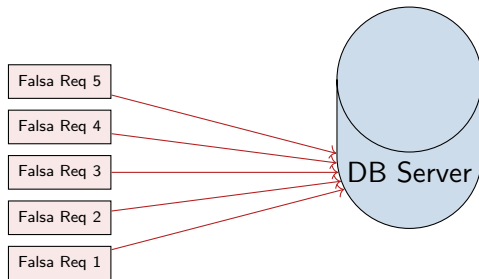
**Impacto:** Dados sensíveis de saúde mental são expostos, violando a privacidade do paciente e leis de proteção de dados (como LGPD).



## Definição

Permite que um atacante torne parte do sistema indisponível para uso legítimo.

- Compromete a **Disponibilidade**.
- **Estratégia:** Sobrecarga de recursos (CPU, Memória, Banda de Rede).
- **Exemplo:** Ataque de Negação de Serviço (DoS) a um servidor de banco de dados.



### Consequência

O servidor gasta todos os seus recursos processando requisições falsas, impedindo que médicos e enfermeiros acessem dados reais de pacientes em emergências.

## Definição

Permite que um atacante manipule ativos do sistema, alterando ou destruindo informações.

- Compromete a **Integridade**.
- **Risco Crítico**: Decisões clínicas baseadas em dados falsos podem ser fatais.
- **Mentcare**: Alterar a dosagem de medicamentos no registro do paciente.

## [CS4] Caso de Estudo: Alteração de Registros

- **Ação:** Um atacante com acesso privilegiado altera o histórico de alergias de um paciente.
- **Perigo:** O médico prescreve um medicamento ao qual o paciente é alérgico, acreditando que o sistema é confiável.

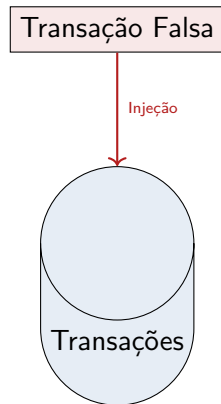


## Definição

Permite que um atacante insira informações falsas no sistema.

- Compromete a **Integridade** e a **Autenticidade**.
- Embora menos "crível" no Mentcare, é uma ameaça crítica em sistemas financeiros.
- **Exemplo:** Adicionar transações bancárias falsas.

**Ação:** Um atacante injeta uma transação de transferência eletrônica no sistema de processamento de um banco. **Resultado:** O sistema reconhece a transação como legítima e transfere fundos para a conta do atacante, sem que tenha havido um depósito real ou transferência de outra conta.



# Obrigado!

Dúvidas?

